

BT Trustwise — enabling eCommerce through trust

B A Cross

The eCommerce market is expanding rapidly and offers tremendous opportunities to BT and its customers. BT is well placed to exploit these opportunities with its combination of trusted networks and eCommerce capabilities. 'Trust' is a key component in enabling eCommerce services across the complete eCommerce delivery process. The provision of certificates to users of the Internet is vital to establishing trust. BT's partnership with VeriSign has quickly enabled BT to offer a wide range of high-quality certification products and services.

BT's certification service, Trustwise, has been delivered in three phases. Phase 1, launched in July 1998, enabled customers to enrol for free Class 1 individual certificates and Class 3 Web server certificates. Phase 2, launched in October 1998, extended the certificate product range and improved resilience and scalability. Phase 3 will involve the transfer of a significant part of the certification service from VeriSign to BT. BT plans to develop the service to provide a wide range of additional eCommerce products, and to use certificates to enhance other BT services. Trustwise has provided a firm foundation on which BT and its customers can build their eCommerce business.

1. Introduction

Electronic business (eBusiness) requires that trust is established between both parties before trading can take place. However, the Internet has frequently been viewed as an unregulated, unsafe place to do business. The provision of digital certificates to users of the Internet is vital to establishing trust. A well-designed and implemented public key infrastructure (PKI) is essential to establish and maintain trust in digital certificates. Two of the main components of a public key infrastructure (PKI) are:

- a Certification Authority run by a trusted third party (TTP), which issues and revokes certificates, according to a published Certification Practice Statement,
- a Registration Authority which authenticates the identities of individuals and organisations who apply for digital certificates (may be operated by a different organisation to the CA).

A number of companies have set up as certification authorities (CAs) and registration authorities (RAs) in the USA and throughout the world. As the number of certificates supplied approaches 10 million, this is rapidly becoming a highly competitive market with a few companies vying for market leadership.

BT recognised in 1997 that there was an opportunity to set up as a CA and RA in the UK. This represented an attractive commercial proposition to authenticate applicants and to supply certificates, building on trust which is one of BT's key brand values in the UK and Europe. It was also

recognised that the infrastructure needed to become a CA provided a valuable foundation for the launch of electronic commerce (eCommerce) services. Many of these services could be enhanced by incorporating the use of digital certificates. BT's entry into the digital certificate market might also help to improve the acceptance and use of digital certificates by increasing trust in their validity.

2. Setting up the BT Trustwise service

BT identified in 1997 that there was a limited window of opportunity to set up as a CA in the UK, as the digital certificate market was maturing rapidly and there were large benefits to early entry. BT had already demonstrated the technology needed to issue and to manage certificates through its pioneering work on the X.509 digital certificate standard [1]. To develop the facilities needed for commercial certificate management and to introduce BT's root certificate into Web browsers and other applications would have taken many months. It would have taken even longer before the majority of potential customers had upgraded to use versions of browsers and other applications which support BT's certificates.

BT decided market entry and acceptance would be speeded by partnering with an existing market leader in supplying digital certificates. As a consequence, BT went into partnership with VeriSign, the US market leader for public certificates. Affiliation with VeriSign offered a number of important advantages:

- rapid market entry by reuse of VeriSign CA tools,
- VeriSign root found in most eCommerce applications, including Web browsers,
- VeriSign are the US market leader for public digital certificates and have a strong position in supplying managed digital certificate services for business,
- VeriSign have strong commercial backing, with shareholders including RSA (Security Dynamics), Cisco, Microsoft and Visa,
- VeriSign have well-developed certificate management tools to manage certificates easily and securely throughout their life cycle,
- VeriSign have a strong development capability and frequently launch new certification products,
- the opportunity to adapt VeriSign's certification practice statement for use by BT in the UK.

VeriSign were also able to offer an existing wide certificate product set, including support for different types of certificate:

- individual — identifies the individual person, for example, used for signing and encrypting e-mails,
- Web site server — identifies the organisation, for example, used to identify the owner of a Web site, and to enable secure connection to it,
- OnSite — certificate management tools to enable an organisation to perform its own authentication of, for example, its employees applying for certificates,
- authenticode — to guarantee the authenticity of software downloaded from the Web,

and support for different 'classes' of certificate depending upon the degree of authentication performed:

- Class 1 — only authenticates that applicants have a unique e-mail address,
- Class 2 — involves an independent check of the applicant's identity, for example against information held on a database which links an individual's e-mail address to their physical address and to information specific to themselves,
- Class 3 — involves a higher level of authentication with a number of independent checks of identity, involving personal appearance with suitable documentation for individuals.

3. Phased approach to launching service

In order to launch the BT certification service, to be called 'Trustwise', as quickly as possible, it was decided to deliver key service elements first, and then to increase the range of products offered. This phased approach also enabled work on the different phases to run in parallel:

- Phase 1 had the main objective of establishing a 'market presence' with a credible set of products, but minimising development — to achieve this Phase 1 was based on a BT Web interface hosted in the UK to VeriSign's existing CA in California,
- Phase 2 aimed to extend the product range and to improve the quality of service, scalability and resilience,
- Phase 3 will see the transfer of the ability to issue OnSite certificates from VeriSign to BT.

3.1 Phase 1 — establish UK market presence

The contract with VeriSign was signed on 5 January 1998, and the Trustwise service launched only six months later on 20 July 1998. The BT components of the Phase 1 service, shown in Fig 1, are hosted at a high security BT service centre in Cardiff:

- featuring the first operational use of biometric access control in BT,
- based on a totally integrated physical security structure,
- using trusted, skilled staff vetted to the equivalent of Government security clearance,
- operating secure 128-bit encrypted e-mail,
- being assessed for BT Computer Emergency Response Team (CERT) registration,
- designed to meet BS7799 [2] and BT Security Evaluation and Certification (BTSEC) standards,
- fully penetration-tested before launch.

A project team of specialists was brought together quickly to develop, integrate and test the processes, hardware and software needed to launch Phase 1. This team was dedicated to the delivery of the service, working very closely with their BT product line counterparts in a rapid application development (RAD) [3, 4] type environment, in order to meet the very aggressive time-scales.

Close communication and co-operation between the product line, the development team, the operations team and VeriSign helped to resolve issues quickly and to keep the

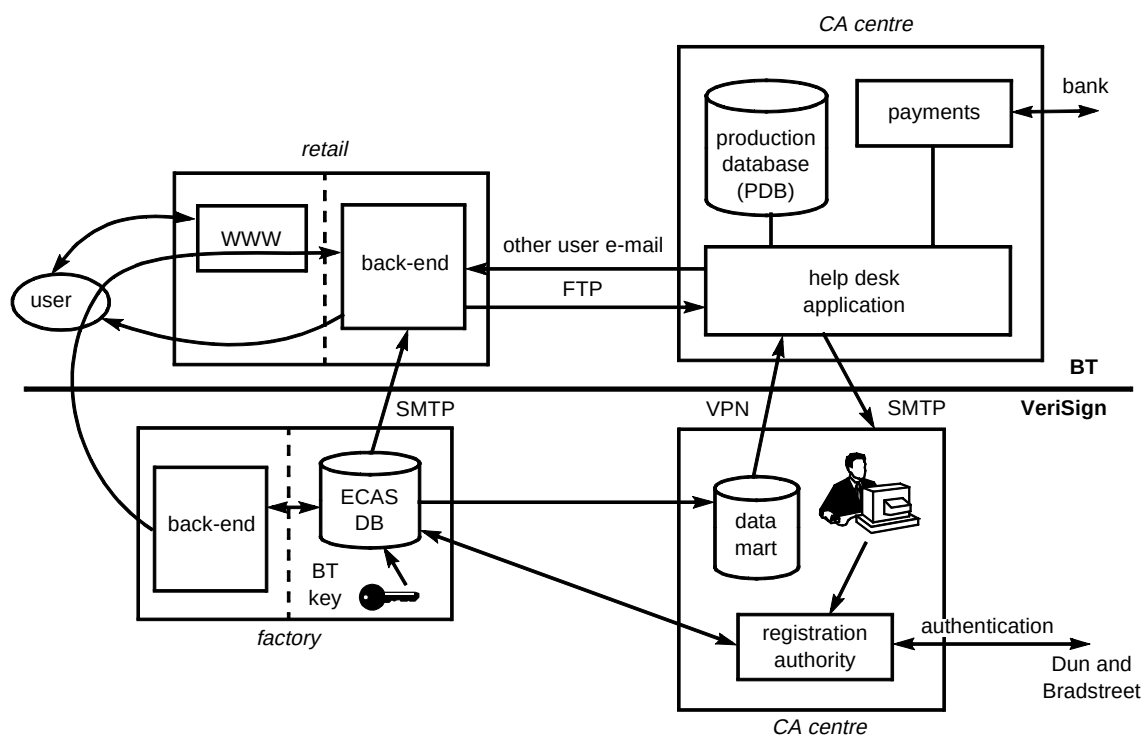


Fig 1 The Phase 1 Trustwise high-level architecture.

work tightly focused on delivery of the product line's requirements. The time difference between the BT teams and VeriSign was used to the advantage of the project. Queries and work for evaluation could be prepared in the UK working day and then responses and the evaluation provided back in the same working day in the USA (and vice-versa).

The main features of Phase 1 were:

- free Class 1 individual certificates,
- paid Class 3 Web site server certificates,
- customers applied for certificates from BT 'Retail' Web site,
- secure links from BT to VeriSign's CA in USA,
- VeriSign 'CA Centre' authenticated organisations,
- VeriSign 'Factory' (ECAS) issued certificates using BT root keys,
- BT 'CA Centre' billed for applications,
- BT production database co-ordinated BT part of certificate life cycle,
- BT helpdesk support for customers,
- BT billing, contract and Certification Practice Statement.

3.2 Phase 2 — expand product range

The objective of this phase was to launch a range of new facilities ready for demonstration at eCommerce '98 at Olympia. The Phase 2 launch on 12 October 1998 was successfully achieved by careful prioritisation of the enhancements to be included, while still achieving sufficient improvements to ensure a credible launch. Requirements for Phase 2 were agreed early in the phase, enabling the development team to focus on their delivery. This helped to avoid requirements 'creep' which can sometimes delay delivery.

The main features of Phase 2 were:

- OnSite, processes and tools to enable organisations to authorise certificates to be issued to their members,
- paid Class 1 individual certificates (free trial Class 1 individual certificates launched in Phase 1),
- Phase 2 being based on the same basic architecture as Phase 1,
- Class 1 and Class 3 e-mail support being transferred from VeriSign to the BT Trustwise helpdesk to improve the quality of service offered to UK customers,
- authentication of Class 3 Web site server certificates being moved to the Trustwise helpdesk,

- scalability and resilience improvements, including improvements to the production database and resilience of the communications links.

3.3 Phase 3 — issue certificates in UK

Based on their experience with BT and a number of other 'affiliates', in mid-1998, VeriSign chose to repackage the functionality of their CA software into:

- service centre — providing 'front-end' facilities for affiliates to perform certificate life-cycle functions, using a Web-based interface,
- processing centre — providing 'back-end' facilities to issue certificates.

A separate 'service centre' and corresponding 'processing centre' are available for each of the main types of VeriSign's certificates. VeriSign advocates that affiliates should implement and host a 'service centre' for each type of certificate they wish to offer. The decision to transfer the 'processing centre' to affiliates is a separate one, as affiliates can continue to use the existing 'processing centre' hosted by VeriSign.

Phase 3 comprises the setting up by BT of:

- OnSite service centre,
- OnSite processing centre,
- Web site service centre.

The transfer of the Web site processing centre to BT will be considered later.

Phase 3 started on 12 October 1998, and is planned to be completed in 1999. The movement of the service centres to the UK will enable all first and second line support to be provided by the BT Trustwise helpdesk (as shown in Fig 2). VeriSign will continue to provide third line support.

As well as the work towards the Phase 3 solution, development also continues to extend the product range and to enhance the service through a series of point releases.

4. Links to other BT services

The Trustwise service provides a firm foundation for other BT services (present and proposed) to use digital certificates to enhance their security:

- BT Internet provides internetworking software, homepage hosting and e-mail to home customers as well as a free individual Trustwise certificate — BT Internet users are able to use their individual digital certificates to secure their e-mail,
- BT WebWorld [5] is a Web site design and hosting service — WebWorld resells Trustwise Web site server certificates to their Web site customers,
- BT Connect to Business offers Web hosting and e-mail to small-to-medium enterprises and closed user groups — customers are able to use Web site server certificates to secure their customer connection to Web sites,
- BT Buynet enables Internet customers to make payments from a few pence to a few pounds to suppliers of Internet products and services — OnSite certificates are used to enable merchants to securely

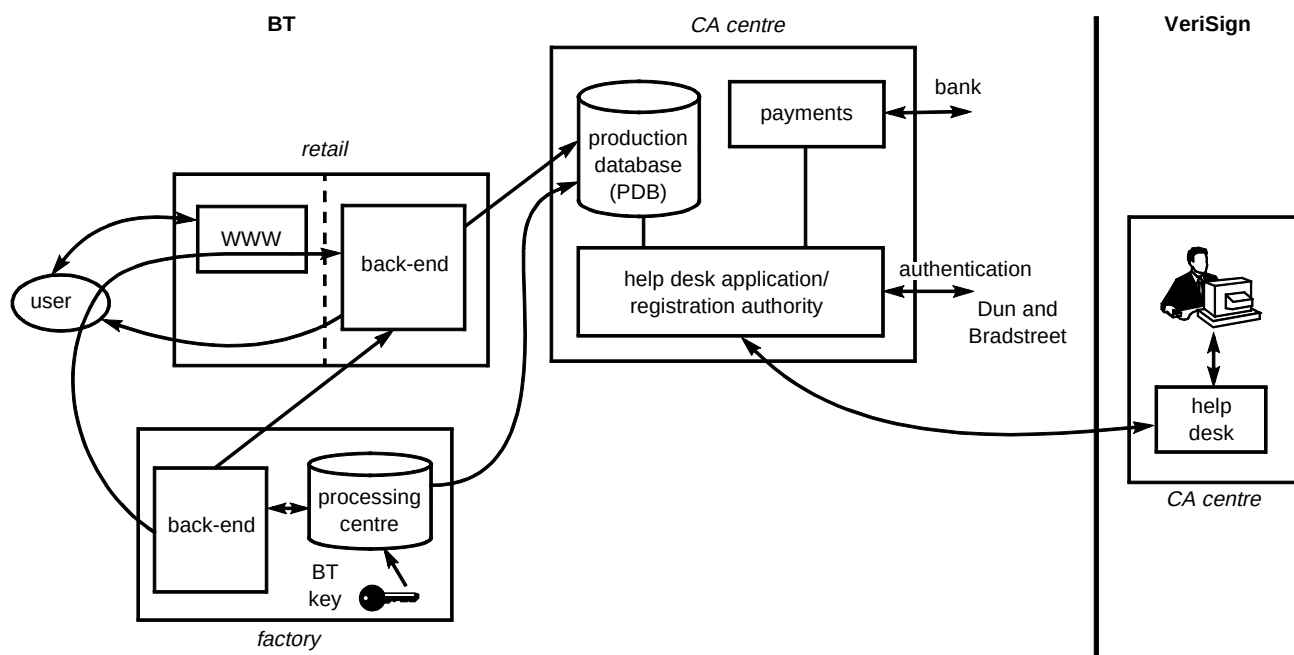


Fig 2 The Phase 3 high level architecture.

identify themselves to the service to refund payments, and merchants can use Web site server certificates to secure customer connections to their sites,

- BT Teamconnect is the internal BT-wide e-mail and employee communications service — OnSite could be used to authenticate BT employees against information held on company databases in order to issue digital certificates to secure e-mail and other in-house applications,
- individual certificates could be used to identify customers to a range of different BT services, including BT Buynet, avoiding the need to enter user name and password for each service — certificates might be used to bring up customer profile information to tailor the services to customers' preferences.

5. Future trust services

As well as completing the transfer of certification and support from VeriSign to BT, other enhancements to the service could be built on its existing capabilities.

- New classes of certificate

For example, some financial applications for public individual certificates require stronger authentication than currently provided by Class 1 certificates. Class 2 or 3 certificates with additional checks on authentication could enable users to undertake substantial financial transactions, such as share dealing.

- Dual key pair support

Signing and encryption serve different functions, i.e. authentication and confidentiality. The legal and regulatory frameworks that are being proposed at European and UK level differentiate between these two uses. There are advantages to using a different public/private key pair for signing and for encryption. For example, the private key used for signing should never be disclosed, but the private key used for decryption may be (see 'key recovery' below).

- Key recovery

To avoid any possibility of forgery, if the private key used for signing is corrupted, it is best if a new key pair is generated and a new signature created. However, the private key used for decryption could be securely archived, so that if corrupted it can be recovered, to ensure that stored, encrypted information can continue to be read. This 'key recovery' facility could be offered by the Trustwise service.

- Smart cards

At present private keys are, by and large, stored securely on the owner's PC and protected by a password. However, if the PC is hacked or stolen, the private key could be used fraudulently. If private keys are stored on a smart card, the user benefits by being able to use it on any PC, and the smart card is kept with the owner and stored more securely. The owner can store a number of digital certificates containing different private keys used for different applications on the same smart card.

- Cross certification

There are a number of different certification hierarchies set up by leaders in digital certification such as VeriSign. Within a hierarchy it is easy to establish the chain of trust needed to validate a certificate. 'Cross certification' between the roots of these hierarchies should enable certificates from one hierarchy to be validated against the root of another cross-certified hierarchy. This could establish a common web of trust, and avoid the need to incorporate the roots of all certificate hierarchies in applications. However, legal and liability issues need to be resolved before this can be realised.

- Notarisation and time stamping

Digital certificates can be used to irrefutably sign a document. If the signatures of two or more parties are received by an electronic notary, this can be used to formally record an agreement between these parties. If a reliable, and verifiable, independent clock is used to 'time stamp' the receipt of digital signatures, the exact time of a contract or other commercial event can be recorded.

- Corporate PKIs

Currently the facilities to manage keys within an organisation to provide desktop security (such as secure e-mail) are disjoint and dependent upon the browser or application. A complete set of client plug-ins for common applications, that integrates with OnSite and corporate directories, is currently being developed and could be offered to BT's customers.

6. Conclusions

The BT Trustwise certification service was launched successfully within very demanding time-scales in July 1998. Trustwise has already been enhanced and new certification products added, and a number of further advanced products are planned. Trustwise has provided a firm foundation on which to build a wide range of new eCommerce services.

Further information on the Trustwise service can be found on: <http://www.trustwise.bt.com/>

Acknowledgements

The launch of the BT Trustwise service was only possible thanks to highly dedicated teams in both BT and VeriSign. The ideas and architecture for the service have been produced by the BT team, and in particular the Trustwise system design authority, Kevin Bosworth. Many of the concepts described in this paper which underpin trust services were originally developed by BT research and prototyping teams led by Dr Peter Skevington and Dr Paul Spurdens.

References

- 1 ITU Recommendation X.509: 'Information technology — open systems interconnection — the directory: authentication framework', (November 1993) — <http://www.itu.int/itudoc/itu-t/rec/x/x500up.html>
- 2 British Standards Institute: 'BS7799 — Information Security Management', (1998) — <http://www.bsi.org.uk/bsis/SGEN/7799.htm>
- 3 DSDM Consortium: 'DSDM Internet White Paper', (1977) — <http://www.planet.bt.co.uk/RAD/download.htm>.
- 4 Carter C J et al: 'Rapid integration and testing of business solutions', *BT Technol J*, **15**, No 3, pp 37—47 (July 1997).
- 5 Cameron I and Patrick D: 'BT WebWorld', *BT Technol J*, **15**, No 2, pp 138—144 (April 1997).



Brian Cross has worked on a wide range of value added services for BT in fifteen years since graduating from Imperial College with a BSc in Physics. He led the team developing the BT Network for Lotus Notes, a service to enable customers to outsource their Notes infrastructure and support to BT. More recently he has led the Electronic Business Solutions group in BT's Products and Services Engineering Centre. This group delivered a number of eCommerce services, including electronic catalogues and shopping, trading environments, micropayments systems and trust services. He has also been project manager for the development of a number of phases of BT Trustwise, providing certificates to users of the Internet. He currently manages Trust and Payments Engineering for BT.